

Plan Integral de Ciberseguridad para CREATIC

Zero Trust · SOC Open Source · DevSecOps · Hardening · Ley 81 · IRP



CREATIC

Integrantes del equipo

Bethancourt, Cecydi · Casis, Diego · Hou, John

Tabla de contenido

Ruta de exposición para la defensa ante Alta Gerencia

1

Contexto, amenazas y riesgo actual

Por qué CREATIC necesita rediseñar su seguridad.

2

Arquitectura AS-IS vs TO-BE

Red plana frente a microsegmentación Zero Trust.

3

ZTNA, MFA y SOC Open Source

Acceso remoto seguro y monitoreo centralizado.

4

DevSecOps y hardening automatizado

Controles preventivos en código, Linux y Windows.

5

Ley 81, riesgos e IRP

Cumplimiento, matriz de riesgos y respuesta a incidentes.

6

Conclusión ejecutiva

Beneficios clave y decisión de aprobación.

Introducción: objetivo ejecutivo

CREATIC necesita pasar de seguridad perimetral a seguridad verificable y continua



Situación actual

Operación híbrida, docentes BYOD, estudiantes activos, servicios SaaS y servidores on-premises con brechas de configuración.



Objetivo del proyecto

Diseñar una arquitectura integral que reduzca riesgo operativo, financiero, legal y técnico en activos críticos de CREATIC.



Principios rectores

Zero Trust: verificar continuamente.
Mínimo privilegio: acceso necesario.
Asumir la brecha: detectar y responder.

Mensaje ejecutivo

La propuesta no solo instala herramientas: rediseña el acceso, segmenta activos críticos, automatiza hardening, integra monitoreo y prepara una respuesta formal ante incidentes.

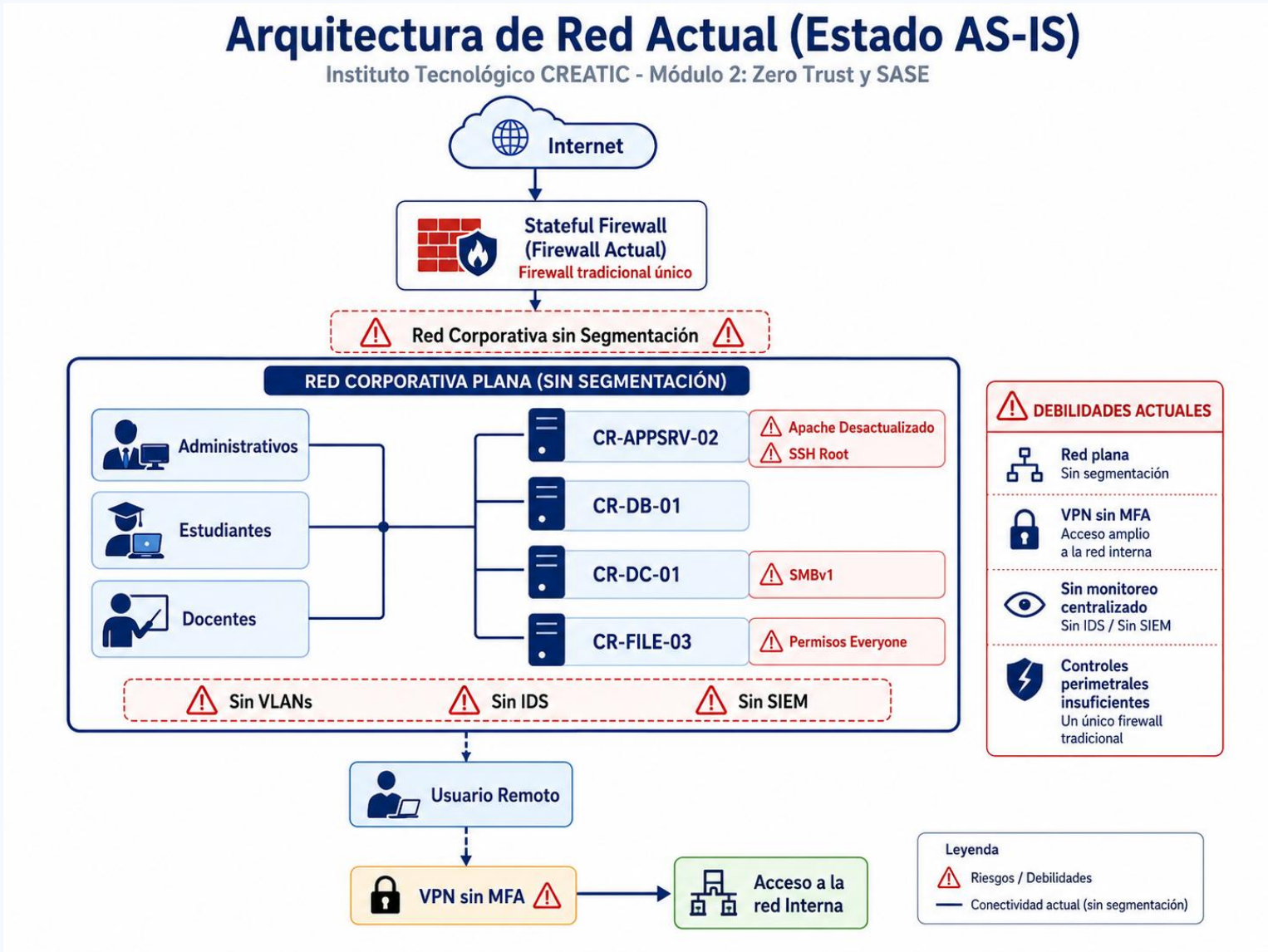
Panorama de amenazas y ruta de ataque

Las amenazas se encadenan: de una credencial robada a un compromiso institucional



Diagnóstico de arquitectura actual — Estado AS-IS

Red plana, VPN sin MFA, sin monitoreo centralizado y dependiente del perímetro



En el estado actual, CREATIC tiene una red plana, sin VLANs ni microsegmentación. El firewall es tradicional, no hay IDS ni SIEM, y el acceso remoto se realiza mediante VPN sin MFA.

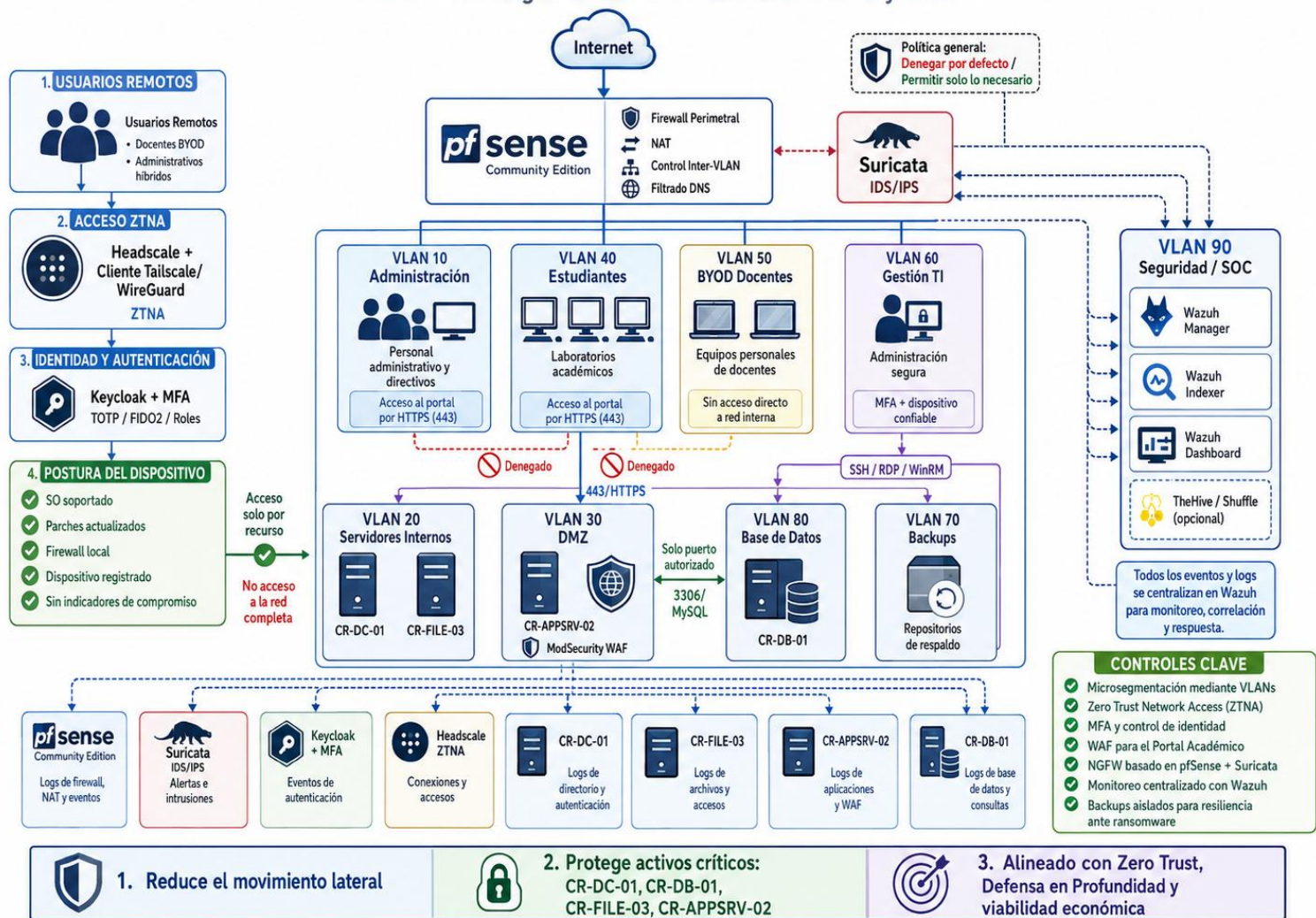
Esto significa que una vez un atacante entra, puede tener visibilidad amplia de la red interna.

Arquitectura propuesta — Estado TO-BE

Zero Trust: denegar por defecto, permitir solo lo necesario y monitorear continuamente

Arquitectura de Red Propuesta (Estado TO-BE)

Instituto Tecnológico CREATIC - Módulo 2: Zero Trust y SASE



Como respuesta, proponemos una arquitectura TO-BE basada en Zero Trust. La red se divide por VLANs: administración, estudiantes, BYOD, DMZ, servidores internos, base de datos, backups, gestión TI y SOC.

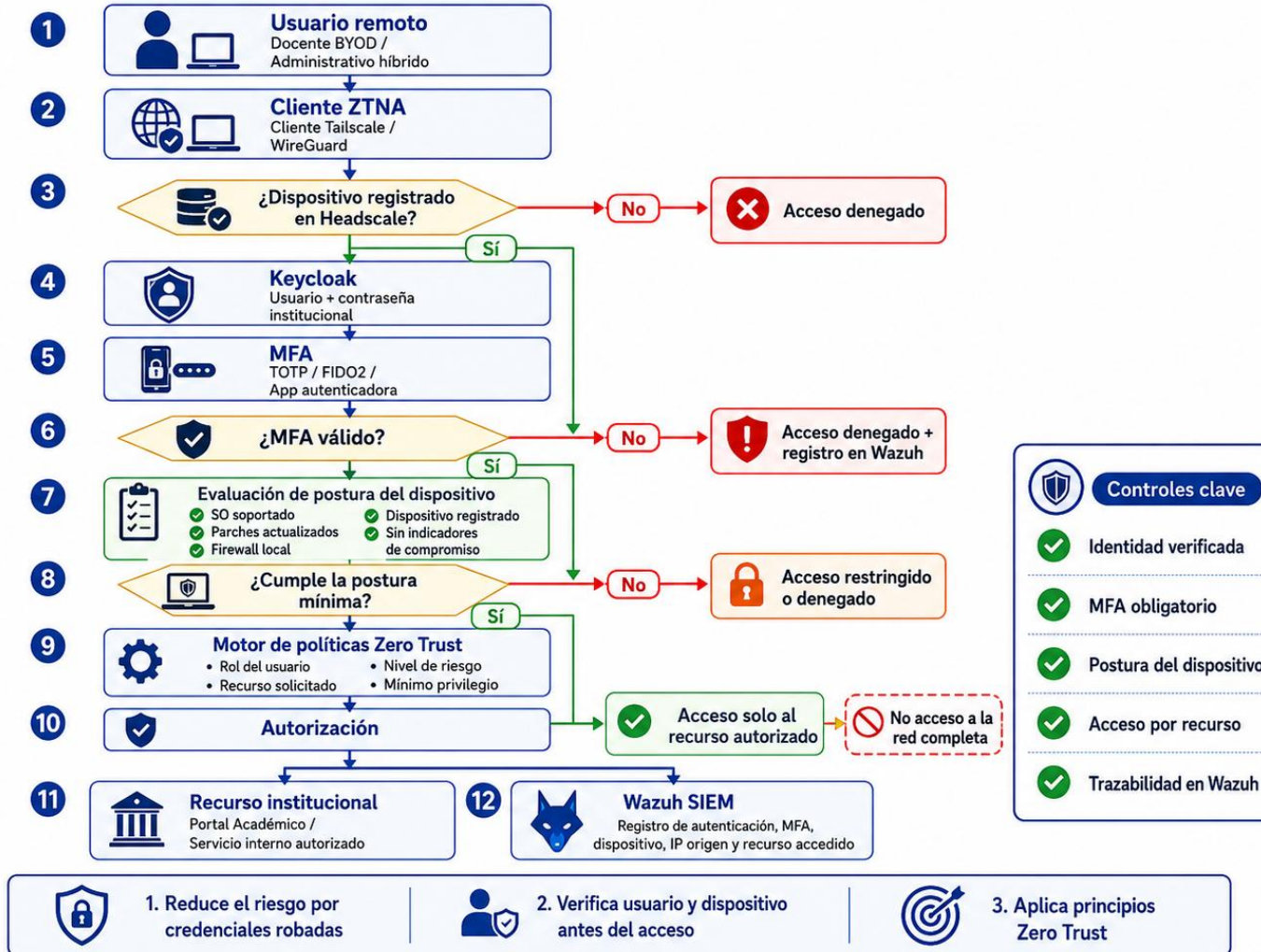
La política general es denegar por defecto y permitir solo lo necesario..

Acceso remoto seguro — ZTNA con MFA

El usuario no entra a toda la red: solo accede al recurso autorizado

Flujo de Autenticación ZTNA con MFA

Instituto Tecnológico CREATIC - Módulo 2: Zero Trust y SASE

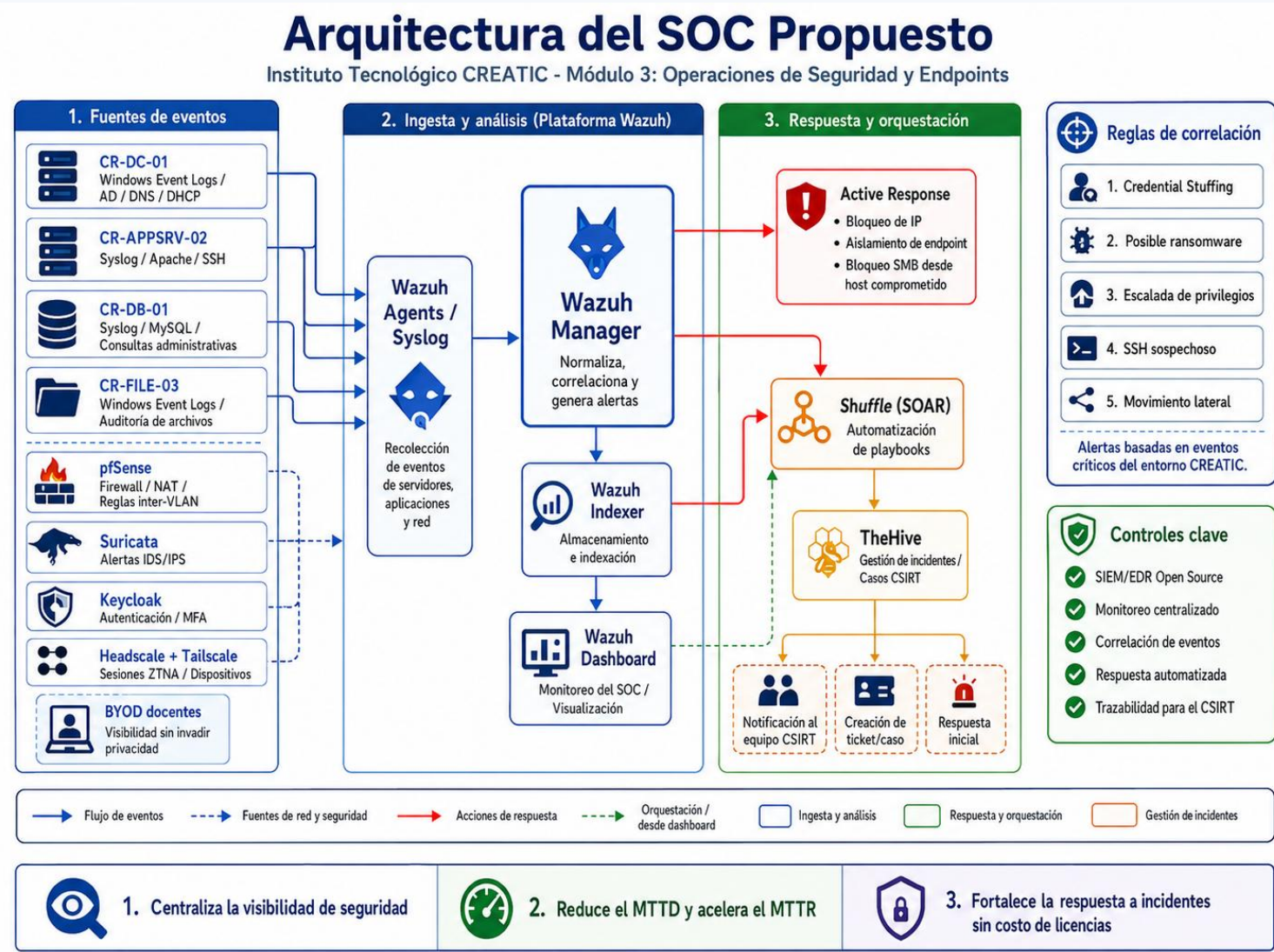


El acceso remoto deja de funcionar como una VPN tradicional. En lugar de entregar acceso completo a la red, ZTNA permite acceso solo al recurso autorizado. Primero se valida el usuario, luego MFA, después el dispositivo registrado y finalmente la postura mínima del equipo.

Si una contraseña es robada, por sí sola no permite entrar. El atacante también tendría que superar MFA, usar un dispositivo autorizado y cumplir las políticas de acceso

Operaciones de seguridad — SOC Open Source

Wazuh centraliza eventos; Shuffle automatiza; TheHive gestiona incidentes

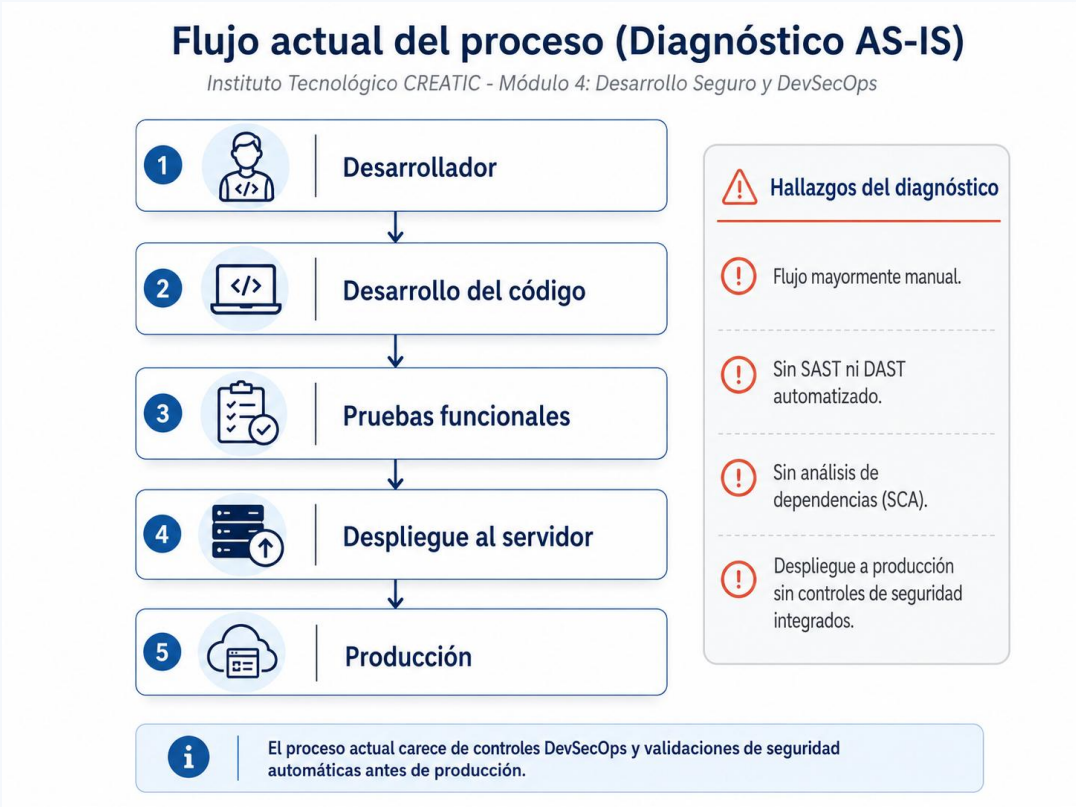


Como el presupuesto para licencias comerciales es cero, la operación de seguridad se construye con herramientas Open Source. Wazuh centraliza eventos de servidores, firewall, IDS/IPS, Keycloak y ZTNA. Luego correlaciona eventos y genera alertas para el SOC.

Shuffle permite automatizar acciones iniciales, como bloqueo de IP o notificación, y TheHive permite documentar los casos del CSIRT. Esto mejora el MTTD y el MTTR, porque la institución detecta más rápido y responde con mayor orden.

Desarrollo seguro — DevSecOps

De despliegue manual a pipeline con controles de seguridad antes de producción



Automatización de hardening — evidencia de laboratorio

Módulo 5 validado en VMs con Ansible para Linux y PowerShell para Windows



Linux — Ansible

Servidores: CR-APPSRV-02 y CR-DB-01

Controles aplicados:

- SSH cambiado a puerto 2222
- PermitRootLogin deshabilitado
- UFW activo y reglas específicas
- Fail2ban activo
- Apache y MariaDB verificados post-hardening
- MariaDB 3306 permitido solo desde CR-APPSRV-02

```
creaticadmin@CR-APPSRV-02: ~/creatic-hardening/linux
TASK [Verificar Apache en CR-APPSRV-02] *****
skipping: [cr-db-01]

TASK [Verificar MariaDB en CR-DB-01] *****
ok: [cr-db-01]

TASK [Resumen final de hardening] *****
ok: [cr-db-01] => {
  "msg": [
    "Servidor: cr-db-01",
    "SSH configurado en puerto: 2222",
    "PermitRootLogin: deshabilitado",
    "UFW: activo",
    "Fail2ban: activo",
    "Verificación post-hardening: completada"
  ]
}

PLAY RECAP *****
cr-db-01      : ok=33  changed=5  unreachable=0  failed=0
skipped=3    rescued=0   ignored=1

creaticadmin@CR-APPSRV-02:~/creatic-hardening/linux$
```



Windows Server — PowerShell

Servidores: CR-FILE-03 y CR-DC-01

Controles aplicados:

- SMBv1 deshabilitado
- SMB Signing habilitado
- Cuenta Guest deshabilitada
- Contraseñas más restrictivas
- Firewall habilitado
- Inbound bloqueado por defecto

```
PS C:\CREATIC-Hardening> Write-Host "===== CR-FILE-03 - POST-HARDENING PARTE 1 ====="
Write-Host "===== IDENTIFICACION DEL SERVIDOR ====="
Get-ServerConfiguration | Select-Object EnableSMB1Protocol | Format-List
net accounts
===== CR-FILE-03 - POST-HARDENING PARTE 1 =====
===== IDENTIFICACION DEL SERVIDOR =====
CR-FILE-03
===== SMBv1 =====
EnableSMB1Protocol : False

===== POLITICA DE CONTRASENAS =====
Force user logoff how long after time expires?: Never
Maximum password age (days): 1
Maximum password age (days): 90
Maximum password length: 12
Length of password history maintained: 5
Lockout threshold: 5
Lockout duration (minutes): 30
Lockout reset window (minutes): 30
Computer role: SERVER
The command completed successfully.
PS C:\CREATIC-Hardening>
```

Cumplimiento regulatorio — Ley 81

Protección de datos personales, calificaciones e información financiera



Cifrado y segmentación

Cifrado de datos sensibles, TLS, VLAN dedicada para CR-DB-01 y control de acceso por mínimo privilegio.



MFA e identidad

Keycloak + MFA protege accesos a recursos críticos y reduce el riesgo por credenciales comprometidas.



Retención de logs

Wazuh centraliza evidencias, aplica roles de acceso y conserva registros según finalidad, criticidad y requerimientos legales.

Ley 81 / principio	Control técnico
Seguridad de datos	Cifrado, MFA, hardening, monitoreo
Confidencialidad	RBAC, mínimo privilegio, trazabilidad
Finalidad y proporcionalidad	Logs mínimos y retención controlada
Artículo 13 / datos sensibles	MFA + ZTNA + registro en Wazuh

Gestión de riesgos — NIST SP 800-30

Matriz con 8 riesgos, al menos uno por cada activo crítico del inventario



CR-DC-01

Compromiso de cuentas / SMBv1

Riesgo: Crítico → Medio



CR-APPSRV-02

RCE, SSH inseguro, despliegues manuales

Riesgo: Crítico → Medio



CR-DB-01

Exfiltración o alteración de datos

Riesgo: Alto → Medio



CR-FILE-03

Permisos Everyone / ransomware

Riesgo: Crítico → Medio

Plan de Respuesta a Incidentes — IRP

Preparado para la inyección de incidente crítico durante la sustentación



Tres acciones inmediatas ante incidente crítico



1. Contener

Aislar host afectado, bloquear IPs en pfSense, cerrar sesiones y deshabilitar cuentas comprometidas.



2. Preservar evidencia

Exportar logs de Wazuh, pfSense, Suricata, Keycloak y servidores afectados.



3. Recuperar

Aplicar parches, rotar credenciales, restaurar desde backups y validar operación segura.

MTTD ≤ 30 min

MTTR ≤ 4 h

Alertas críticas ≥ 95%

Wazuh en 100% servidores

Conclusión ejecutiva

CREATIC pasa de un modelo perimetral reactivo a una arquitectura verificable, segmentada y monitoreada



Reduce probabilidad

MFA, ZTNA, DevSecOps y hardening disminuyen la probabilidad de compromiso inicial.



Limita impacto

Microsegmentación, mínimo privilegio y backups evitan que un incidente escale a toda la red.



Mejora respuesta

Wazuh, Shuffle, TheHive e IRP reducen MTTD, MTTR y dan trazabilidad al CSIRT.

“Esta arquitectura no elimina todo riesgo, pero reduce la probabilidad, limita el impacto y mejora la capacidad de respuesta de CREATIC.”

Muchas gracias por su atención.